Resumen Detallado: El Historian, OPC, ICCP y la Forense OT en Entornos SCADA

Referencia: Documento de Cátedra N° 11 — Tema El Historian, OPC, ICCP y la Forense OT en Entornos SCADA.pdf
Asignatura: Tecnología Operativa (2026) - Licenciatura en Ciberdefensa (FADENA)
Unidad 3: Sistemas de Supervisión y Sectores Críticos

Introducción y Contexto Doctrinal

El documento aborda la seguridad en entornos industriales tomando como eje un caso real de 2022 en una planta petroquímica de Medio Oriente. En este incidente, un equipo de respuesta detectó un pico de presión controlado que activó una válvula de alivio. La investigación forense reveló que, 72 horas antes del evento, un atacante no autorizado realizó consultas exhaustivas al servidor *historian*, descargando semanas de datos sobre temperaturas, presiones y caudales.

Con esta información, el adversario comprendió estadísticamente el comportamiento normal del proceso y modificó un *setpoint* dentro del rango de variación histórica documentada. Como consecuencia, el sistema de alarmas no se disparó, el operador no intervino y la anomalía se ejecutó según lo diseñado.

Conclusión Doctrinal

El servidor *historian* no es exclusivamente una herramienta forense para el defensor; es también el principal instrumento de reconocimiento del adversario:

- **Acceso de lectura:** Permite aprender a atacar el proceso físico sin ser detectado.
- **Acceso de escritura:** Permite borrar las huellas de las acciones realizadas.
- **Concentración de riesgo:** Reúne en un único servidor la memoria operativa completa de la instalación, centralizando la fragilidad de la tríada AIC en su formulación industrial.

---

1. El Servidor Historian en la Arquitectura SCADA

El *historian* (o *process historian*) es el componente del sistema SCADA encargado de almacenar el registro histórico completo de todas las variables monitoreadas del proceso. A diferencia de la Base de Datos de Tiempo Real (RTDB), que retiene únicamente el valor actual de cada variable con latencias de milisegundos a segundos, el *historian* preserva el historial completo desde el inicio de la operación.

En el **Modelo Purdue**, el *historian* se ubica estratégicamente en la interfaz entre los **Niveles 2 y 3**: recibe datos del servidor MTU (Nivel 2) y los expone a los sistemas de gestión, reportes y plataformas ERP corporativas (Nivel 3).

Roles Operativos y Riesgos Asociados

1. **Registro Operativo:** Almacena el historial continuo del comportamiento de las variables para operadores e ingenieros de proceso.

    - *Riesgo (Integridad):* Modificar el registro permite falsificar el historial para ocultar anomalías.
2. **Instrumento Forense:** Funciona como la "caja negra" del entorno industrial para equipos de respuesta a incidentes y auditores.
    - *Riesgo (Disponibilidad e Integridad):* Destruir el servidor elimina la evidencia del ataque; modificar los datos históricos invalida la investigación forense.
3. **Fuente de Inteligencia Operativa:** Describe de manera matemática y precisa los patrones de producción, umbrales y correlaciones para analistas de datos.
    - *Riesgo (Confidencialidad):* El acceso de lectura no autorizado permite al adversario modelar firmas operativas normales y diseñar ataques que evadan la detección de las alarmas.

---

2. Tipos de Historian y Bases de Datos de Series Temporales

A diferencia de los Sistemas de Gestión de Bases de Datos Relacionales (RDBMS como Oracle, SQL Server o PostgreSQL) optimizados para registros estructurados en filas mediante SQL, las bases de datos de los *historians* están diseñadas como **Bases de Datos de Series Temporales (TSDB)**.

Características de las TSDB Industriales

- **Modelo de datos temporal:** La unidad de datos es el punto temporal de una variable, estructurado como un triplete: `(timestamp, valor, calidad)`.
- **Compresión especializada:** Implementan algoritmos específicos que reducen el volumen de almacenamiento entre un 80% y un 95% en comparación con el registro continuo sin procesar.
- **Optimización de rendimiento:** Diseñadas para soportar la escritura masiva de miles de actualizaciones por segundo y responder consultas sobre rangos temporales extensos (días, semanas o años) con baja latencia.
- **Acceso multiprotocolo:** Proveen interfaces de comunicación compatibles con OPC DA, OPC UA, OPC HDA, consultas SQL y APIs REST.

Principales Tecnologías en el Mercado

- **OSIsoft PI System (AVEVA PI):** Líder dominante con más del 65% del mercado en plantas de proceso continuo (petróleo, gas, energía, agua). Su arquitectura se basa en "PI Interfaces" que corren como servicios de Windows con privilegios elevados, constituyendo un vector potencial de compromiso.
- **GE Proficy Historian:** Amplia adopción en instalaciones equipadas con suites de GE/Emerson. Típicamente instalado en servidores Windows con cuentas de servicio de alto privilegio y dependencia de soporte remoto.
- **Aspen InfoPlus.21 (IP.21):** Software propietario especializado y de alta prevalencia en la industria petroquímica y de refinación.
- **InfluxDB / TimescaleDB:** Soluciones de código abierto con uso creciente en despliegues modernos, entornos IIoT y sistemas de nueva generación. Facilitan la implementación nativa de TLS y autenticación, aunque presentan riesgos de seguridad si se despliegan rápidamente con configuraciones por defecto.

Mecanismo de Compresión: Exception y Compression

Tomando como referencia la arquitectura de OSIsoft PI, el almacenamiento se optimiza mediante un proceso de dos etapas:

1. **Exception (Excepción):** Actúa como un filtro en la fuente (interfaz). Solo transmite los valores al servidor si la variación respecto al último punto registrado supera un umbral configurable (*exception deviation*).
2. **Compression (Compresión):** Aplica el algoritmo "*Swinging Door*" sobre los datos que superaron la excepción. Mediante interpolación lineal, el sistema almacena únicamente los puntos estrictamente necesarios para reconstruir la curva del proceso dentro de una precisión configurable.

> **Nota de Ciberdefensa:** Los umbrales de compresión impactan directamente en la precisión forense. Si se configuran tolerancias demasiado amplias para ahorrar almacenamiento, un atacante puede alterar las variables de proceso realizando modificaciones sutiles que operen "por debajo del umbral de memoria", impidiendo que el *historian* genere un registro de la anomalía.

---

3. OPC: El Middleware de Integración SCADA

OPC (*Open Platform Communications*) es el conjunto de estándares industriales que define interfaces de software para el intercambio de datos. Funciona como el middleware de integración de la arquitectura SCADA, permitiendo que el *historian*, las HMIs y las aplicaciones corporativas interconectadas lean datos de la MTU sin necesidad de desarrollar controladores propietarios para cada fabricante.

Comparativa de Versiones de OPC

Característica	OPC DA (Data Access) / OPC HDA	OPC UA (Unified Architecture)
Estándar	1996 (DA) / 2003 (HDA)	2008 (Activo y recomendado)
Plataforma	Exclusivo de Windows (COM/DCOM)	Multiplataforma (Windows, Linux, embebidos)
Transporte	Microsoft DCOM (Puertos RPC dinámicos)	TCP/IP puerto 4840 (Binario) o 443 (HTTPS)
Autenticación	Seguridad local de Windows (ACLs, cuentas)	Certificados X.509, usuario/clave o anónimo
Cifrado	No nativo (Requiere soluciones como IPSec)	Integrado de forma nativa (Ej: *Basic256Sha256*)
Perfil de Riesgo	**Alto:** Expuesto a vulnerabilidades de explotación DCOM (como el gusano *Blaster*). Los puertos dinámicos impiden reglas estrictas de firewall.	**Bajo-Medio:** Arquitectura moderna. El riesgo principal radica en certificados no validados o modo anónimo activo.
Estado Actual	Legado. Presente en sistemas anteriores a 2010. Requiere encapsulación via "*OPC tunnel*".	Estándar moderno de adopción activa en la industria.

---

4. ICCP: Comunicaciones entre Centros de Control

ICCP (*Inter-Control Center Communications Protocol*), formalizado internacionalmente bajo el estándar **IEC 60870-6/TASE.2**, es el protocolo diseñado para el intercambio de datos en tiempo real entre centros de

control de diferentes organizaciones del sector eléctrico (generadoras, transmisoras, distribuidoras y operadores del sistema interconectado). Es, estructuralmente, el protocolo de comunicación **SCADA-to-SCADA**.

Implicancias de Ciberdefensa

- **Ubicación en el Modelo Purdue:** Opera en el límite crítico entre los **Niveles 3 y 4**, interconectando redes de distintas compañías. Un compromiso de este protocolo posee el potencial de generar impactos sistémicos a escala regional o nacional.
- **Modelo Bilateral:** Utiliza las denominadas "*Bilateral Tables*", las cuales configuran de forma explícita qué puntos de datos, alarmas y comandos específicos están autorizados a compartirse entre las dos partes. Si un atacante altera estas tablas, puede expandir sus privilegios de lectura/escritura en la red vecina.
- **Debilidades de Implementación:** Aunque el estándar define mecanismos de seguridad, en la práctica operativa real la autenticación suele encontrarse deshabilitada y carece de cifrado nativo (dependiendo de capas externas como VPNs o TLS). Esto expone al protocolo a interceptación de tráfico (revelando el estado completo de la red eléctrica nacional), ataques de inyección de comandos o ataques de *replay*.

---

5. El Historian como Instrumento Forense OT

La forensia OT es la disciplina científica que analiza la evidencia digital en entornos industriales para reconstruir la cronología de incidentes, delimitar el alcance del compromiso y establecer la causa raíz de las anomalías físicas. El *historian* constituye la fuente de evidencia primaria en estas investigaciones.

Utilidad Forense de las Trazas Temporales

- **Establecer la cronología precisa:** Determina el instante exacto del inicio de la anomalía, el orden secuencial en que se afectaron las variables y el tiempo transcurrido hasta la detección.
- **Identificar la firma operativa:** Permite diferenciar fallas mecánicas de ataques lógicos analizando los patrones temporales coordinados y la distribución de cambios en los *setpoints*.
- **Evaluar el nivel del adversario:** Distingue si el ataque fue informado (manipulaciones sutiles dentro de parámetros normales que denotan un reconocimiento previo del *historian*) o desinformado (producción de valores extremos con impacto inmediato).
- **Verificar la integridad post-incidente:** Valida, mediante la correlación con sistemas de seguridad como el SIS (Sistema Instrumentado de Seguridad), si el proceso retornó de forma efectiva a condiciones estables.

Limitaciones Técnicas para la Investigación

1. **Pérdida por Compresión:** Los algoritmos descritos (*Exception/Compression*) pueden descartar micro-variaciones intermedias que contengan datos de valor forense.
2. **Desalineación del Reloj:** La validez de la línea de tiempo depende de la sincronización estricta de todos los nodos mediante protocolos de tiempo (NTP). Relojes divergentes entre PLCs, RTUs y el *historian* imposibilitan la correlación exacta de los eventos.
3. **Ausencia de Auditoría de Escritura:** Generalmente, el *historian* acepta los datos inyectados por la MTU de manera ciega. Si la MTU es comprometida, el *historian* archivará datos falsificados como si fuesen reales.

4. **Carencia de Logs de Acceso (Sistemas Legados):** Los sistemas antiguos no registran las consultas de lectura de los usuarios, permitiendo que un adversario realice tareas de reconocimiento sin dejar rastro de su actividad.

> **Diferencia Estructural (SIEM vs. Historian):** En el ámbito corporativo IT, el SIEM centraliza logs de eventos de seguridad (inicios de sesión, alertas de red, cambios de configuración). En el entorno industrial OT, el *historian* registra los eventos del proceso físico (estados de actuadores, flujos, presiones). Una investigación forense OT completa e integral exige la correlación coordinada de ambas plataformas.

---

6. Anti-Forense OT: El Historian como Objetivo del Adversario

La anti-forense OT engloba el conjunto de técnicas orientadas a destruir, contaminar o degradar la evidencia digital con el fin de impedir la investigación posterior a un incidente. Al ser el componente de mayor valor informacional, el *historian* es el objetivo prioritario del atacante.

6.1. Destrucción del Historian

Consiste en la eliminación lógica o física del registro para generar una pérdida total de visibilidad histórica:

- **Malware tipo Wiper (Ej: KillDisk):** Herramienta utilizada en el ciberataque a la red eléctrica de Ucrania en 2015. Sobrescribe el *Master Boot Record* (MBR) del disco, destruyendo el sistema operativo. Tácticamente, se despliega al final de la operación de ataque (luego de provocar el apagón) con el objetivo deliberado de entorpecer las tareas de respuesta e investigación. En plantas medianas donde el *historian* comparte servidor con la HMI, el impacto es doble y simultáneo.
- **Formateo y Sobreescritura Silenciosa:** Consiste en borrar el volumen de datos de la TSDB y rellenarlo con bits aleatorios antes de ejecutar la acción principal del ataque, eliminando el histórico pero manteniendo el servidor en funcionamiento para registrar datos nuevos, enmascarando el vacío temporal.

6.2. Manipulación Sutil del Historian

A diferencia de la destrucción (que alerta inmediatamente sobre un incidente), la manipulación sutil busca mantener la coherencia del registro borrando únicamente las huellas del ataque de forma quirúrgica:

- **Modificación de valores históricos:** Alteración directa de los registros archivados correspondientes a la ventana de tiempo del ataque, reemplazándolos con valores simulados dentro de los rangos normales de operación.
- **Falsificación de marcas de tiempo:** Modificación de los *timestamps* de los datos para desalinear la secuencia temporal y romper la capacidad de correlación con los logs de los firewalls o dispositivos de red.
- **Manipulación de la base de configuración:** Alteración de los parámetros de compresión durante el ataque para forzar una pérdida agresiva de resolución matemática en las variables alteradas, haciendo imposible comprobar la anomalía estructural.

---

7. Contramedidas para la Integridad del Historian

La protección del *historian* como instrumento forense confiable requiere la aplicación de controles arquitectónicos y de seguridad específicos para el entorno industrial:

- **Control de Acceso de Escritura Estricto:** Restricción estricta mediante ACLs del sistema operativo y configuraciones del servidor para garantizar que únicamente los servidores MTU o FEP autorizados y autenticados posean permisos de escritura sobre la base de datos de procesos. Todas las demás conexiones externas deben ser forzadas a solo lectura.
    - *Complejidad:* Baja.
- **Historian Replicado en DMZ OT:** Configuración de un servidor *historian* espejo en la zona desmilitarizada (DMZ) industrial que replique en tiempo real los datos del servidor de producción de la red OT. Este nodo espejo debe ser configurado como de solo lectura para redes externas. Si el *historian* de producción es destruido por un *wiper*, el espejo preserva la evidencia hasta el momento del impacto.
    - *Complejidad:* Media (requiere segmentación de red).
- **Sellado Criptográfico de Registros (Hash Chaining):** Implementación de un mecanismo criptográfico donde cada nuevo registro de datos de series temporales incluya un hash que encadene matemáticamente al registro inmediatamente anterior (concepto análogo a *blockchain*). Cualquier modificación retroactiva de valores o marcas de tiempo romperá la integridad de la cadena, alertando sobre la manipulación.
    - *Complejidad:* Alta (suele requerir software moderno o capas de desarrollo adicionales).
- **Registro de Acceso de Lectura Auditado:** Activación y almacenamiento obligatorio de todas las consultas de lectura realizadas contra los tags del *historian* (identificando usuario, timestamp, variables y rangos de datos consultados). Este log debe desviarse en tiempo real a un servidor de auditoría independiente para detectar actividades anómalas de reconocimiento previas a un ataque.
    - *Complejidad:* Media-Baja.
- **Backup del Historian en Servidor de Auditoría Físicamente Separado:** Respaldo periódico y sistemático de la base de datos del *historian* hacia un servidor de auditoría aislado que carezca de conectividad física o lógica con la red OT o la DMZ. La transferencia de datos se realiza bajo estrictos controles mediante medios físicos verificados. Representa el último recurso forense ante escenarios de destrucción total de la infraestructura de red.
    - *Complejidad:* Baja en tecnología / Media en disciplina operativa.